



Prof. Iaçanã Ianiski Weber

Exercícios adaptados de Paar, Pelzl e Güneysu, *Understanding Cryptography*, 2ª ed., Springer, 2024 (Capítulo 14, *Key Management*). Cobre as aulas de **Estabelecimento de Chave Simétrica/Kerberos** e de **MITM, Certificados e PKI**.

Parte I: Distribuição de Chave Simétrica (KDC e Kerberos)

Exercício 1

Uma chave-mestra k_{MK} é trocada de forma segura entre as partes (p.ex. via DHKE com certificados). Em seguida, chaves de sessão são geradas regularmente por uma **KDF**, garantindo *frescor* caso uma chave de sessão seja comprometida. Considere três métodos ($h(\cdot)$ é uma função hash segura e k_i é a i -ésima chave de sessão): (Livro, Problema 14.1)

$$(1) \quad k_0 = k_{MK}, \quad k_{i+1} = k_i + 1 \quad (2) \quad k_0 = h(k_{MK}), \quad k_{i+1} = h(k_i)$$

$$(3) \quad k_0 = h(k_{MK}), \quad k_{i+1} = h(k_{MK} \parallel i \parallel k_i)$$

- (a) Quais são as principais diferenças entre os três métodos?
- (b) Qual(is) método(s) oferece(m) **Perfect Forward Secrecy (PFS)**?
- (c) Suponha que Oscar obtenha a n -ésima chave de sessão (p.ex. via um vírus). Quais sessões ele consegue decifrar em cada método?
- (d) Qual método permanece seguro se a chave-mestra k_{MK} for comprometida? Justifique.

Exercício 2

Imagine uma rede ponto-a-ponto em que **1000 usuários** desejam se comunicar de forma autenticada e confidencial. (Livro, Problema 14.2)

- (a) Quantas chaves são necessárias *ao todo* se forem usados algoritmos **simétricos sem** um centro de distribuição de chaves (KDC), isto é, com uma chave distinta para cada par de usuários?
- (b) Como esse número muda se introduzirmos um **KDC** como terceira parte confiável?
- (c) Qual é a principal vantagem de um sistema baseado em KDC em relação ao cenário sem KDC?
- (d) Quantas chaves são necessárias se usarmos algoritmos **assimétricos**?

Exercício 3

Você deve escolher os algoritmos criptográficos de um **KDC** no qual ocorrem duas classes de cifra-gem: (Livro, Problema 14.3)

- $e_{k_{U,KDC}}(\cdot)$, onde U é um nó (usuário) qualquer da rede, a **KEK** de longo prazo;
- $e_{k_{ses}}(\cdot)$, para a comunicação entre dois usuários, a chave de **sessão**.

Você dispõe de implementações de duas cifras (**PRESENT** com chave de 80 bits e **AES-256**) e foi orientado a usar algoritmos diferentes para cada classe. Qual cifra você usa para cada classe? Justifique sua resposta.

Exercício 4

Mostre que o **PFS não é garantido** no protocolo Kerberos simplificado (Needham–Schroeder). Mostre como Oscar pode decifrar comunicações **passadas e futuras** se: (Livro, Problema 14.7)

- a KEK de Alice, k_A , for comprometida;
- a KEK de Bob, k_B , for comprometida.

Exercício 5

Seu primeiro trabalho é projetar um sistema de **TV por assinatura** (*pay-TV*) que usa cifragem para impedir o roubo de sinal por escuta. Como protocolo de troca de chave usa-se **Diffie–Hellman** com módulo de 2048 bits; porém, por usar *hardware* legado barato, só há **DES** disponível como algoritmo de cifragem de dados. Adota-se a derivação de chave (Livro, Problema 14.9)

$$K^{(i)} = f(K_{AB} \parallel i),$$

onde f é uma função de mão única.

- Verifique se um atacante consegue **armazenar** um filme inteiro com esforço (custo) razoável. Suponha taxa de dados de **1 Mbit/s** ($= 10^6$ bit/s) e que os filmes mais longos a proteger duram **2 horas**. Quantos GB (com 1 MB = 10^6 bytes e 1 GB = 10^9 bytes) devem ser armazenados para um filme de 2 horas? Isso é realista? (*Cuidado para não confundir bits e bytes.*)
- Suponha que o atacante consiga encontrar uma chave DES em **10 minutos** por força bruta com *hardware* dedicado. Com que **frequência** uma chave deve ser derivada para impedir a decifragem *offline* de um filme de 2 horas em menos de **30 dias**?

Parte II: Man-in-the-Middle, Certificados e PKI

Exercício 6

Considere o Diffie–Hellman e suponha que Oscar execute um **ataque Man-in-the-Middle**, como visto em aula. Use os parâmetros $p = 467$, $\alpha = 2$, com $a = 228$ (Alice) e $b = 57$ (Bob); Oscar usa o expoente $o = 16$. (Livro, Problema 14.11)

- Calcule os pares de chaves k_{AO} e k_{BO} (i) da forma como *Oscar* os calcula e (ii) da forma como *Alice* e *Bob* os calculam.
- O que esse resultado mostra sobre a necessidade de **autenticar** as chaves públicas?

Exercício 7

Considere o **DHKE com certificados**. Suponha que Oscar tente um ataque **ativo (de substituição)** das seguintes formas: (Livro, Problema 14.13)

- (a) Alice quer se comunicar com Bob. Quando Alice obtém $\text{Cert}(B)$ de Bob, Oscar o substitui por um $\text{Cert}(O)$ (*válido!*), dele próprio. Como essa falsificação será detectada?
- (b) Mesmo cenário: Oscar agora tenta substituir a chave pública de Bob, b_B , pela sua própria chave b_O (mantendo ID_B). Como essa falsificação será detectada?

Exercício 8

Em um domínio, os usuários compartilham os parâmetros Diffie–Hellman α e p , e a chave pública DH de cada usuário é certificada por uma **CA**. A comunicação é feita por um DHKE seguido de cifragem simétrica (p. ex. AES). (Livro, Problema 14.15)

Suponha que Oscar obtenha o algoritmo de assinatura da CA, **inclusive sua chave privada**. Ele consegue **decifrar mensagens antigas** (que havia armazenado) trocadas entre dois usuários *antes* do comprometimento? Se não, descreva qual **outro ataque** Oscar passa a poder realizar. Justifique.

Exercício 9

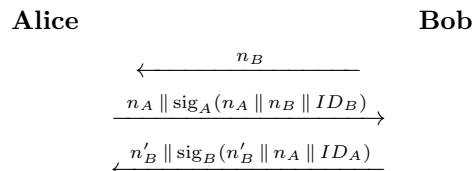
Desenhe o diagrama de um protocolo de **transporte de chave** (semelhante ao visto na Seção 14.4) no qual se usa **cifragem RSA com um certificado**. Indique claramente: a transmissão do certificado, a verificação do certificado com $k_{pub,CA}$, a escolha e o transporte da chave de sessão, e a cifragem dos dados com uma cifra simétrica. (Livro, Problema 14.17)

Exercício 10

O **Pretty Good Privacy (PGP)** é um esquema amplamente usado para proteger e-mails e outros dados digitais, e **não** exige necessariamente o uso de autoridades certificadoras. Descreva o **modelo de confiança** do PGP e como funciona, na prática, o gerenciamento de chaves públicas. Aponte uma **vantagem** e uma **desvantagem** em relação ao modelo hierárquico de CAs. (Livro, Problema 14.19)

Exercício 11

Analise o protocolo a seguir, com o qual dois usuários se autenticam mutuamente. Assume-se que cada usuário possui um algoritmo de assinatura digital e que as chaves públicas de verificação já foram corretamente distribuídas. (n_X é um *nonce* gerado pelo usuário X .) (Livro, Problema 14.21)



- (a) Descreva todos os passos de ambas as partes e explique o **objetivo** de cada passo (em especial, o papel dos *nonces* e das identidades ID).
- (b) Oscar executa um ataque bem-sucedido conhecido na literatura como **ataque de intercalação** (*interleaving attack*): ele inicia uma sessão com Bob e usa as respostas de Alice (e vice-versa), apenas **repassando** mensagens. Explique como o ataque funciona e quais são suas **consequências**.
- (c) **Contraste** o *interleaving attack* com o ataque **Man-in-the-Middle** (Parte II): contra o que cada um atenta (autenticação de entidade vs. troca de chave) e por que as consequências do MITM tendem a ser mais abrangentes.